LAB 5

Static Code Analysis

Gym Membership System - Analysis, fixes and verification

Student	B Varun	**SRN**	PES1UG24CS109
Section	Not specified in the supplied materials	**Python file**	gym_membership_system.py
Repository	github.com/bvarun-blip/SE-LABS-PES1UG24CS109	**Date**	30 October 2026

Tools used: Pylint 4.1.3, Bandit 1.9.4 and Flake8 7.5.0 on Python 3.14.0.

Submission scope: original and corrected static-analysis reports, issue/fix table, reflection responses, terminal screenshots and Git commit/push evidence.

Prepared from the supplied Lab 5 handout, six generated report files, issue/reflection notes and screenshots from the working session.

1. Introduction and objective

Static code analysis examines source code without running the program. It helps identify potential bugs, security weaknesses and style violations early in development. In this lab, the Gym Membership System Python script was analyzed and updated using three static-analysis tools.

The stated lab objective is to improve Python code quality, security and style by using Pylint, Bandit and Flake8 to identify and fix common programming issues. The handout asks for at least four documented fixes, corrected code, before-and-after analysis evidence and reflection.

1.1 Tools and their roles

Tool	Purpose in this lab	Examples of findings
Pylint	General Python code-quality review: naming, docstrings, unused variables, design and logic warnings.	Mutable default arguments, bare exceptions, unused variables, missing docstrings and naming conventions.
Bandit	Security-oriented static analysis that flags common vulnerable or unsafe coding patterns.	eval(), weak hashes, non-cryptographic random values, shell execution and hard-coded secrets.
Flake8	Style and formatting checks, including PEP 8 whitespace and line-length rules.	Unused imports, long lines, bare except and missing final newline.

1.2 Analysis workflow

- The original script was preserved as gym_membership_system_before.py before remediation.
- Pylint, Bandit and Flake8 were run against the original script and their outputs were saved as *_before.txt reports.
- The findings were documented and the script was updated in separate Pylint, Bandit and Flake8 commit stages.
- All three tools were rerun against the corrected script and their outputs were saved as *_after.txt reports.
- The three source-code commits were pushed to the student GitHub repository.

2. Issue identification and fixes

The original reports surfaced security findings, reliability concerns and code-quality/style problems. The table below records representative issues and the corresponding remediation. Line numbers refer to the original gym_membership_system.py file as identified in the supplied reports.

Issue	Type / tool	Original line	Description	Fix approach
Unsafe eval()	Security / Bandit B307; Pylint W0123	42	Evaluating a string can execute arbitrary Python expressions.	Replaced the expression argument with a numeric discount rate and validated the allowed range.
Shell command through os.system()	Security / Bandit B605	58	Building a shell command with a filename can create command-injection risk.	Removed the shell command and used Python output for the status message.
Hard-coded portal secret	Security / Bandit B105	70	A secret stored in source code can be exposed to anyone with repository access.	Removed the hard-coded secret from the source and stopped assigning it in main().
Weak MD5 hash	Security / Bandit B324	47	MD5 is not appropriate for security-sensitive hashing.	Replaced MD5 with SHA-256.
Non-cryptographic random PIN	Security / Bandit B311	51	The random module is not designed for security-sensitive values.	Used secrets.randbelow() to generate the four-digit PIN.
Bare except/pass	Reliability / Bandit B110; Pylint W0702	26	Catches every exception and can hide unexpected failures.	Replaced the try/except block with members.pop(member_id, None).
Mutable default list	Bug / Pylint W0102	15	A list default is shared between function calls.	Changed the default to None and initialized a fresh list inside the function.
Unused variables and None comparison	Code quality / Pylint, Flake8	31, 32, 41	Unused locker_deposit/base_fee variables and == None comparison reduced clarity.	Removed unused assignments and used an explicit None check / membership lookup.
File opened without context manager/encoding	Reliability / Pylint W1514, R1732	55	A file may not be closed if an error occurs; platform-default encoding is implicit.	Used with open(..., encoding="utf-8") so file closure is guaranteed.
Style, naming and formatting	Style / Pylint, Flake8	Multiple	Function names, docstrings, long lines, unused import and final newline needed improvement.	Applied snake_case names, docstrings, consistent formatting, removed unused import and added a final newline.

3. Before-and-after verification

The values below are taken from the supplied report files and the screenshots captured during the tool runs.

Tool	Before	After	Observed change
Pylint	4.81/10	**10.00/10**	The final report records a 10.00/10 rating, up by 5.19 points.
Bandit	6 findings: 3 low, 1 medium, 2 high	**0 findings**	The final report says “No issues identified”; severity and confidence counts are all zero.
Flake8	9 violations	**0 violations**	The final report is an empty 0-byte file, meaning Flake8 emitted no style findings.

3.1 Verification notes

The Pylint after-report contains the 10.00/10 score. The Bandit after-report contains a PowerShell native-command diagnostic preamble caused by redirecting native stderr in the Windows terminal; the Bandit result section itself explicitly states “No issues identified” and lists zero findings in every severity/confidence category. The Flake8 after-report is empty (0 bytes), consistent with no reported violations.

3.2 Report commands

```
py -m pylint gym_membership_system.py > reports\pylint_before.txt 2>&1
py -m bandit -r gym_membership_system.py > reports\bandit_before.txt 2>&1
py -m flake8 gym_membership_system.py > reports\flake8_before.txt 2>&1

After fixes, the same three commands were run with *_after.txt output filenames.
```

3.3 Git submission evidence

The terminal screenshots show three separate commits: 9284f3f (Pylint), df069d9 (Bandit) and 1f2b30d (Flake8). A subsequent git push output confirms that main was pushed to the remote repository at github.com/bvarun-blip/SE-LABS-PES1UG24CS109. The status screenshot also showed the local branch up to date with origin/main.

4. Reflection

The uploaded three-page lab handout refers to reflection questions but does not include their exact wording. The responses below address the lab learning outcomes; compare them with the exact questions in the lab manual if a separate question sheet was provided.

1. What is static code analysis, and why is it useful?

Static code analysis checks source code without executing the program. It helps identify possible bugs, security weaknesses and style problems early, making the program safer and easier to maintain.

2. What are the roles of Pylint, Bandit, and Flake8?

Pylint checks general code quality, naming, unused variables and programming practices. Bandit looks for common security weaknesses. Flake8 checks Python formatting and PEP 8 style rules such as whitespace and line length.

3. What issues were identified and fixed in this program?

The program contained unsafe eval(), a shell command built with os.system(), a hard-coded secret, weak MD5 hashing, a mutable default list, a bare exception handler and file handling without a context manager. These were replaced with safer and clearer approaches.

4. How did static analysis improve the program?

The tools helped identify problems that were easy to overlook during normal execution. Fixing them improved security, reliability, readability and maintainability while preserving the gym membership program’s main functions.

Submission checklist

- ■ Corrected gym_membership_system.py pushed to the personal GitHub repository.
- ■ Three separate source-code commits for Pylint, Bandit and Flake8 fixes.
- ■ Six report files: before and after outputs for all three tools.
- ■ Issue-identification table with more than four issues and fixes.
- ■ Before-and-after analysis screenshots and reflection responses included in this consolidated PDF.

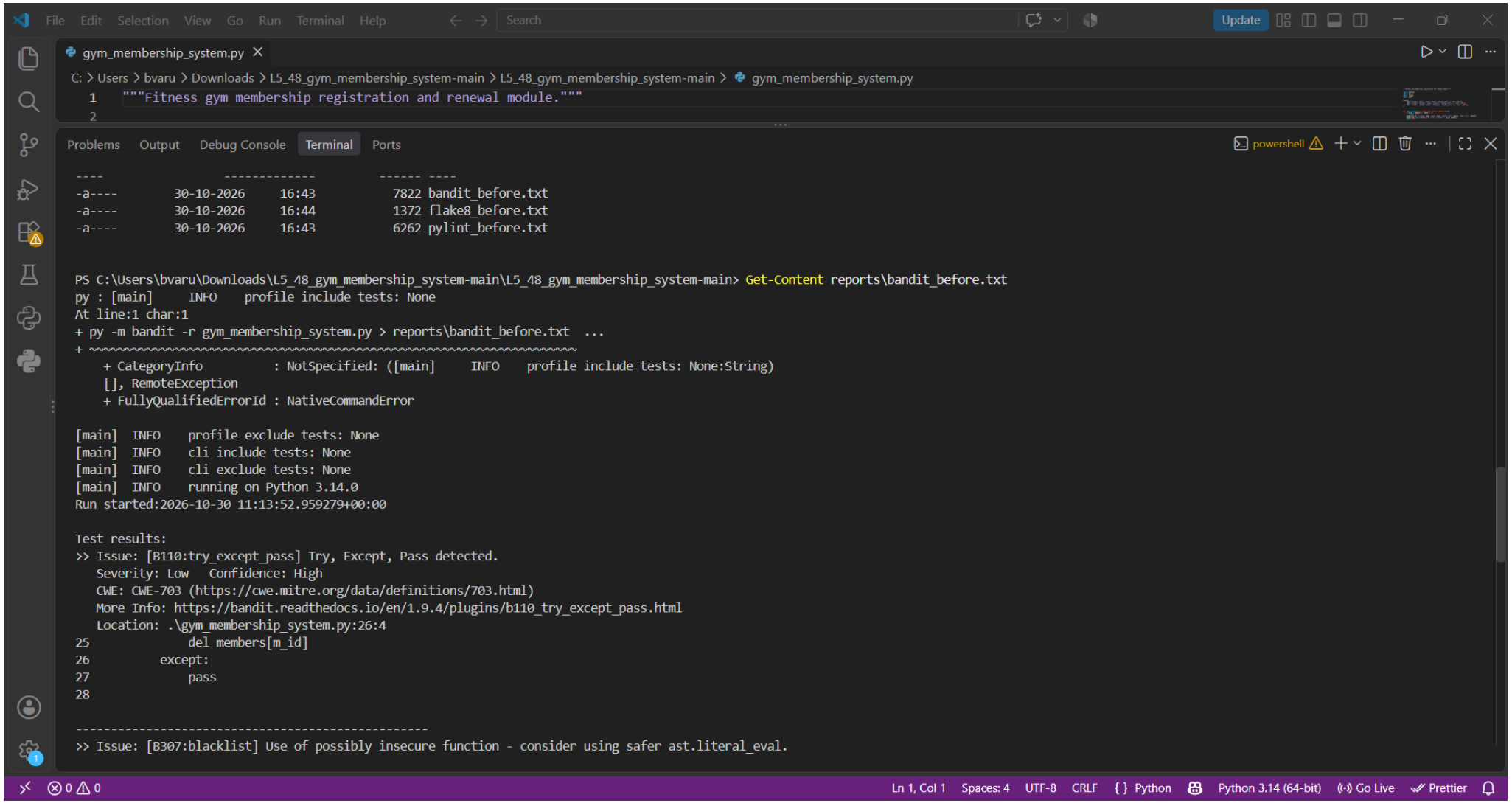
Before submitting the Google Form: enter the correct section in the form; the section value was not present in the materials supplied for this PDF.

Appendix A. Terminal screenshot evidence

The screenshots below are the original terminal captures supplied in the conversation. They document the before-and-after analyzer runs and Git operations.

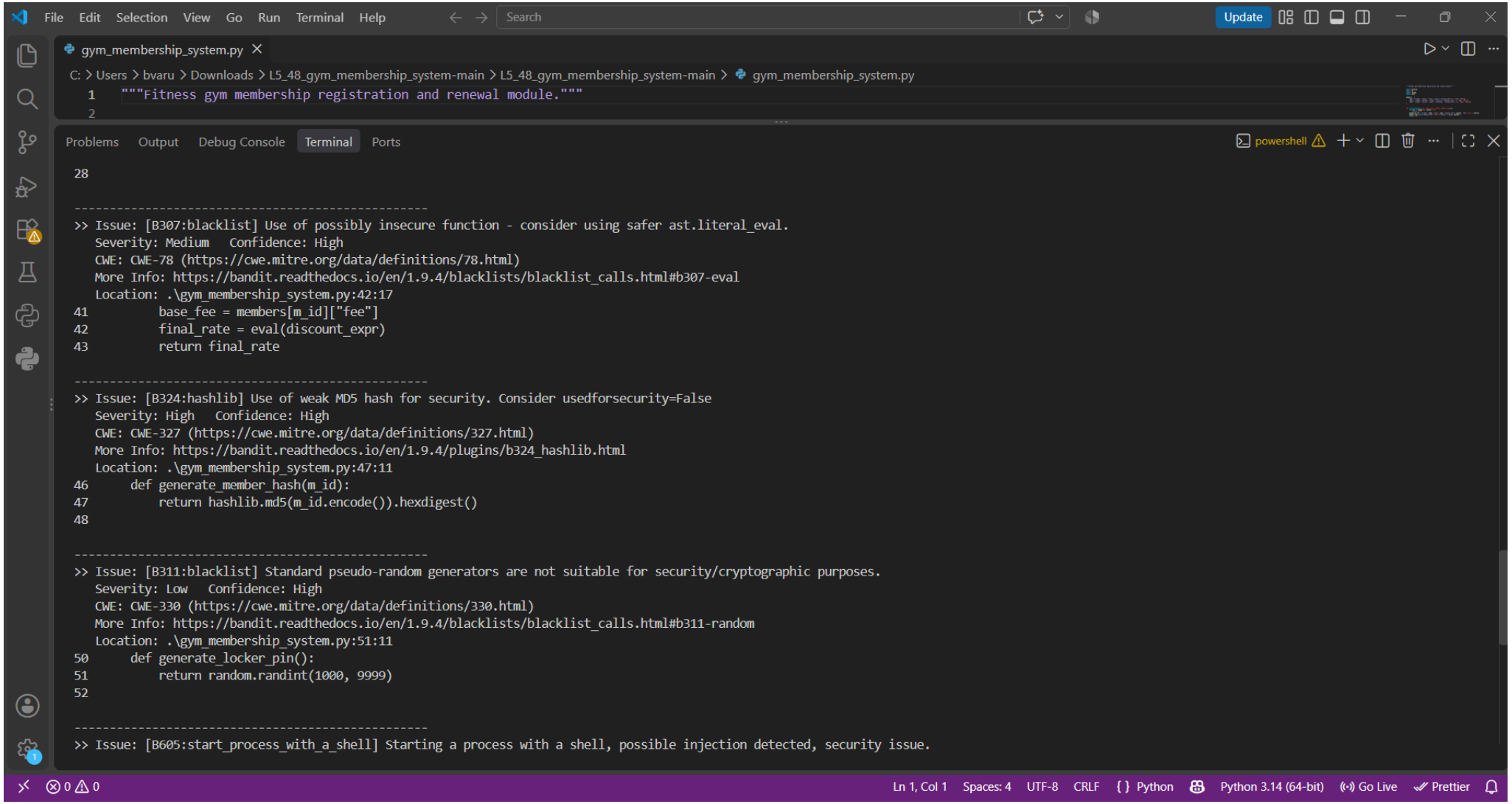
Before fixing - Bandit initial findings

The Bandit run begins and shows the first reported security findings.



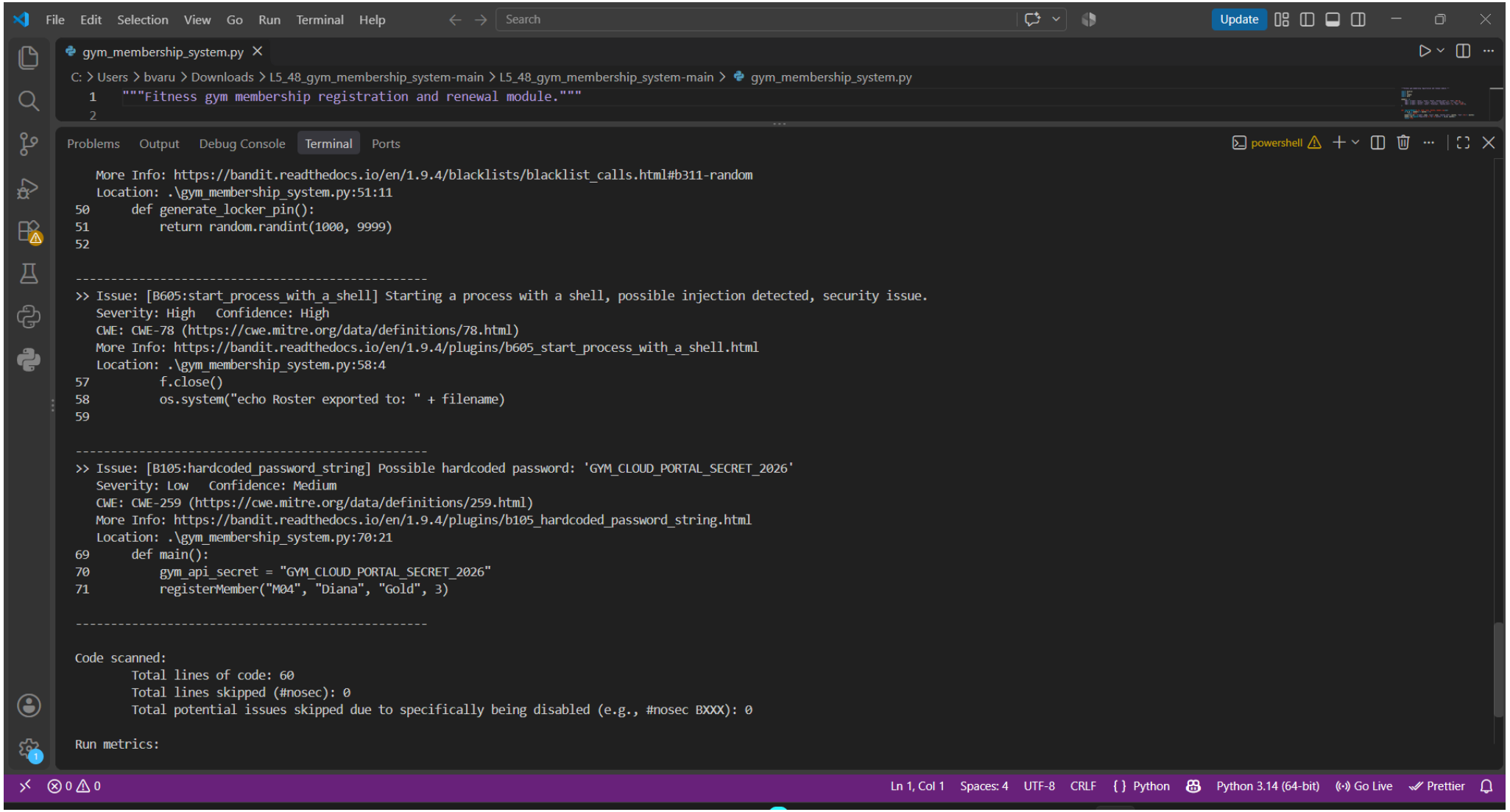
Before fixing - Bandit findings continued

The original report identifies eval(), MD5 and random PIN generation concerns.



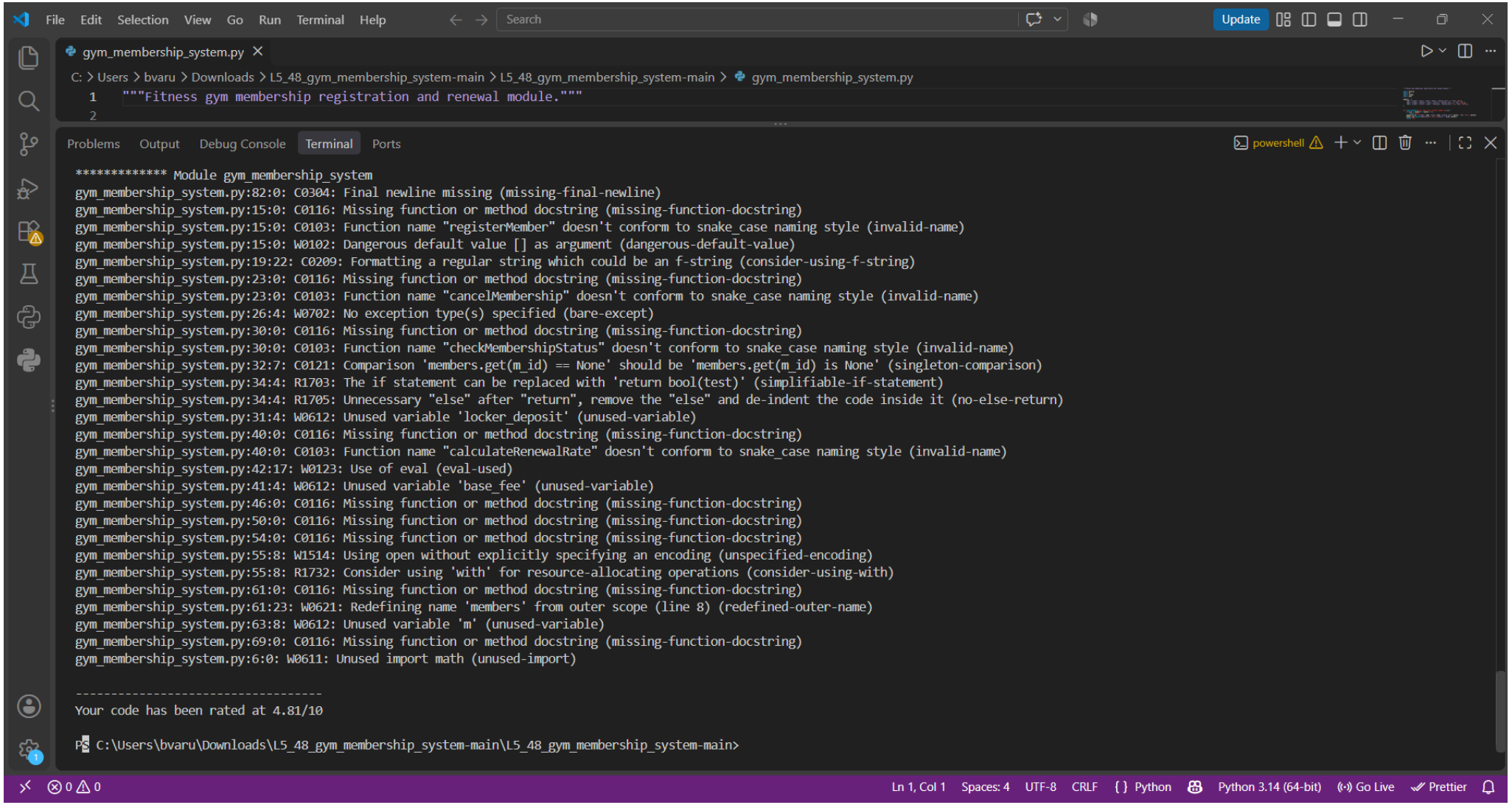
Before fixing - Bandit remaining findings and summary

The original report also flags shell execution and a hard-coded secret; the summary reports six findings.



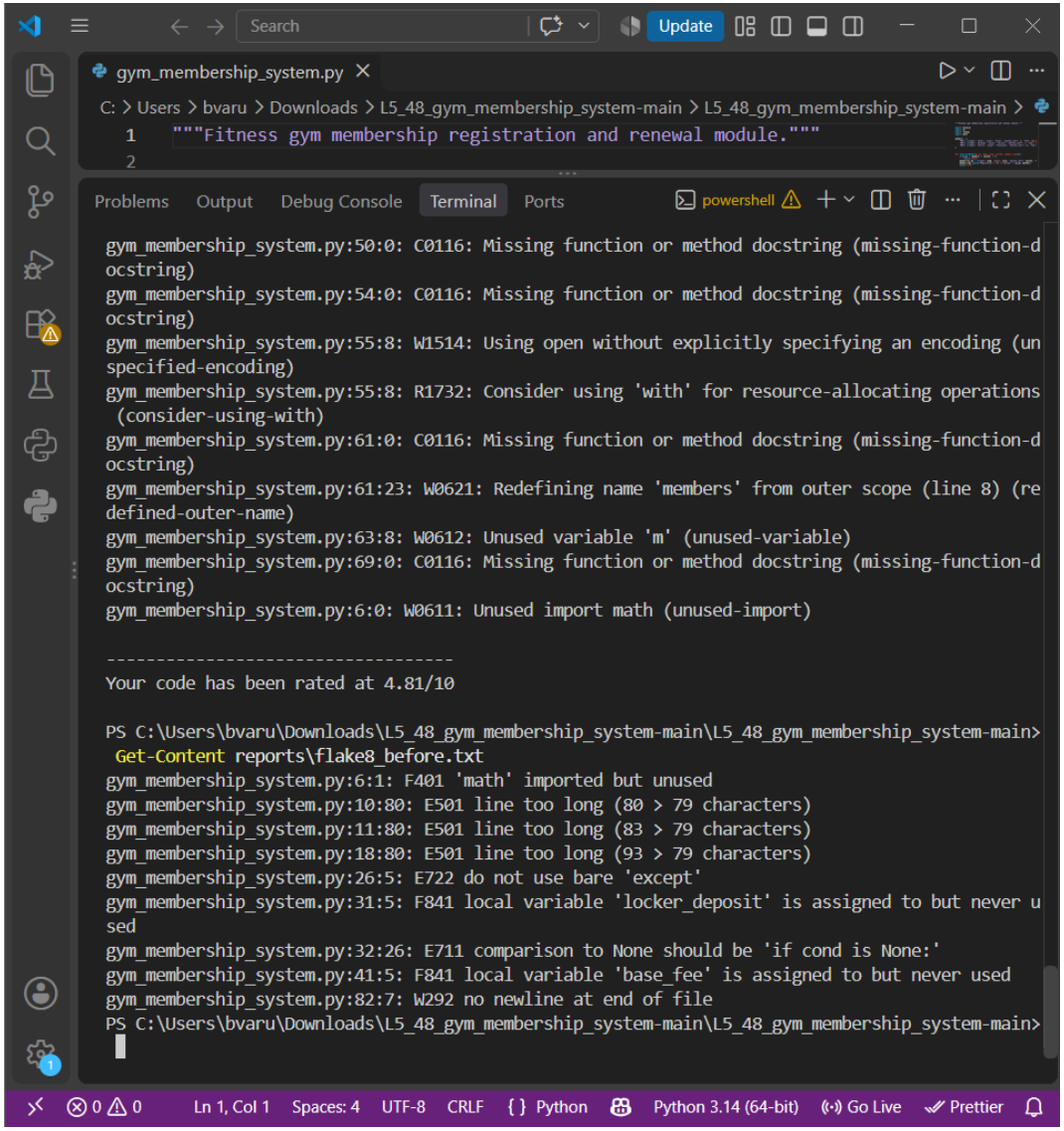
Before fixing - Pylint

The original Pylint report ends with a score of 4.81/10.



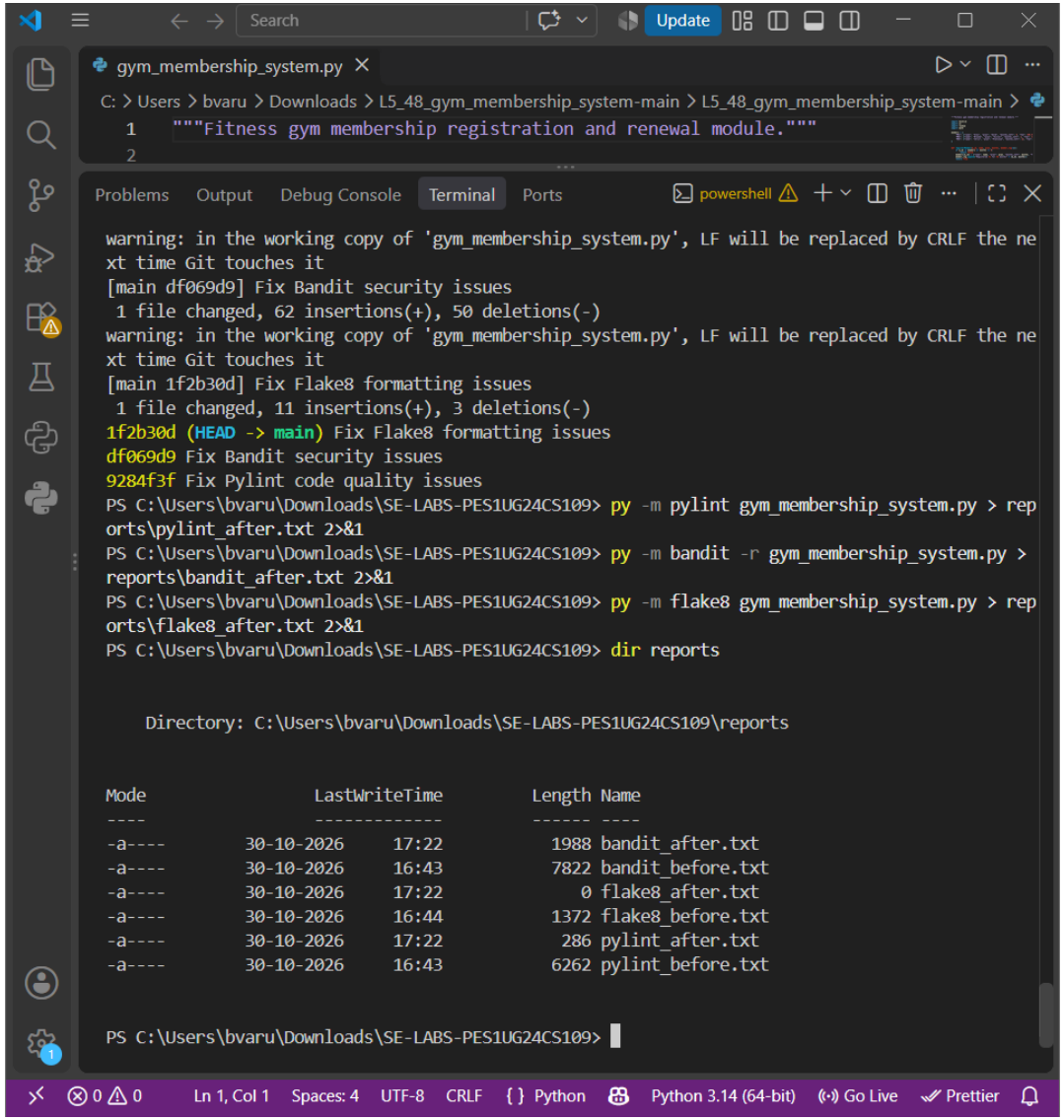
Before fixing - Flake8

The original Flake8 output lists unused imports, long lines, bare except, unused variables, a None comparison and a missing final newline.



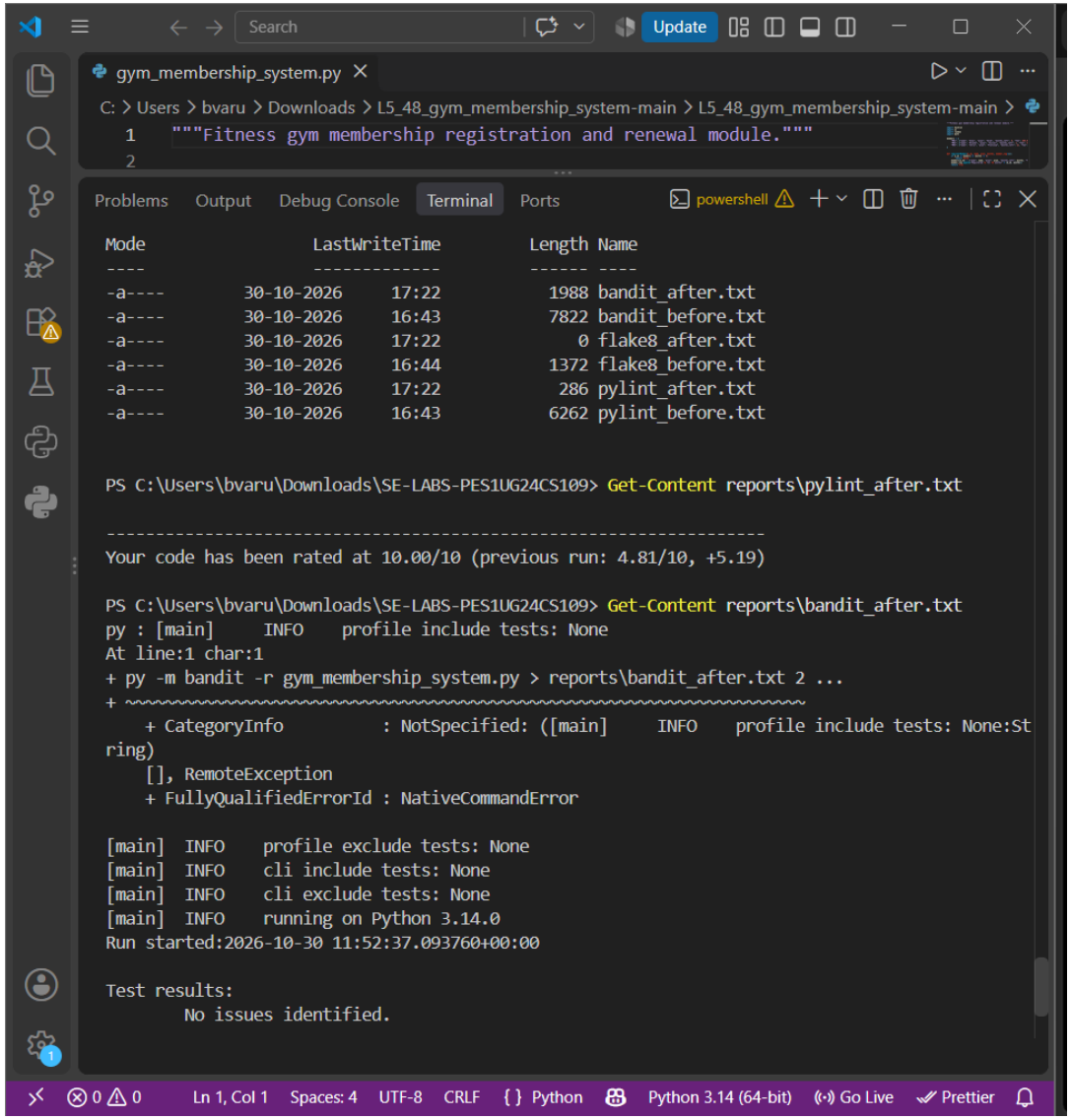
After fixing - Pylint and report files

The reports folder contains all six before/after files; pylint_after and bandit_after were generated, and flake8_after is 0 bytes.



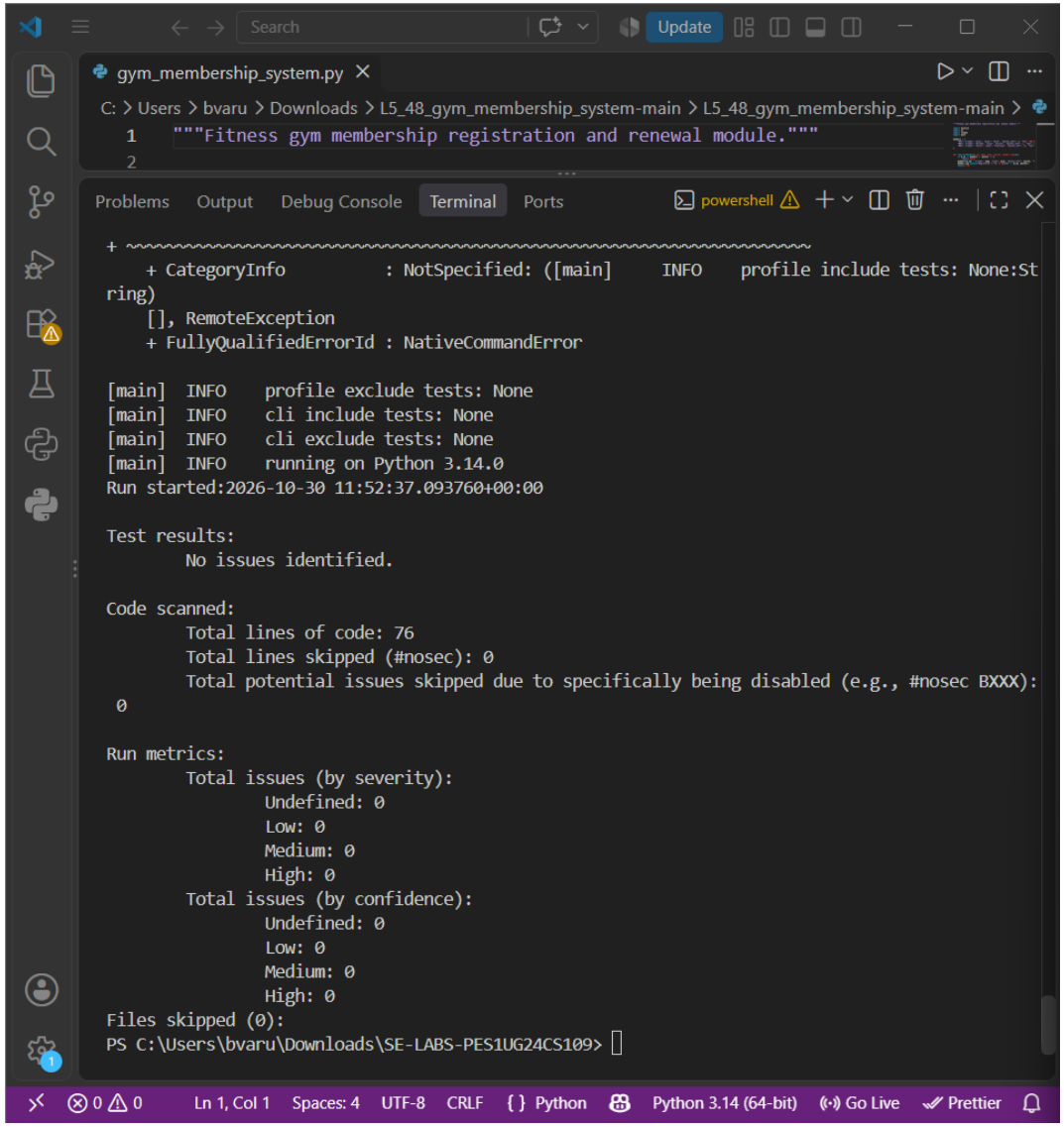
After fixing - Pylint and Bandit results

The terminal shows the Pylint score of 10.00/10 and Bandit “No issues identified”.



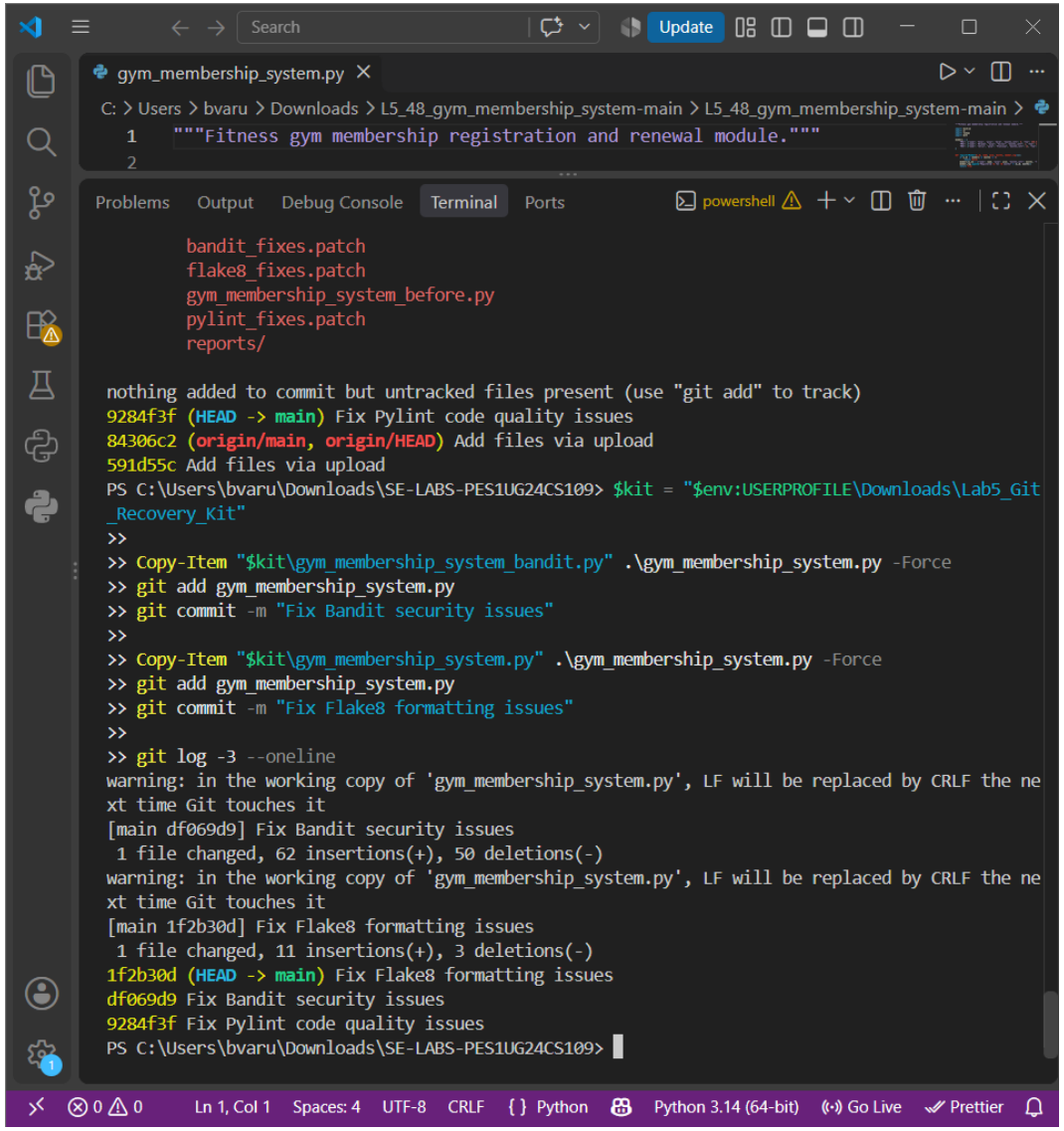
After fixing - Bandit issue counts

Bandit reports zero issues in all severity and confidence categories.


Search
Update
gym_membership_system.py
C: > Users > bvaru > Downloads > L5_48_gym_membership_system-main > L5_48_gym_membership_system-main >
1 """Fitness gym membership registration and renewal module."""
2
Problems
Output
Debug Console
Terminal
Ports
powershell
+ ~~~

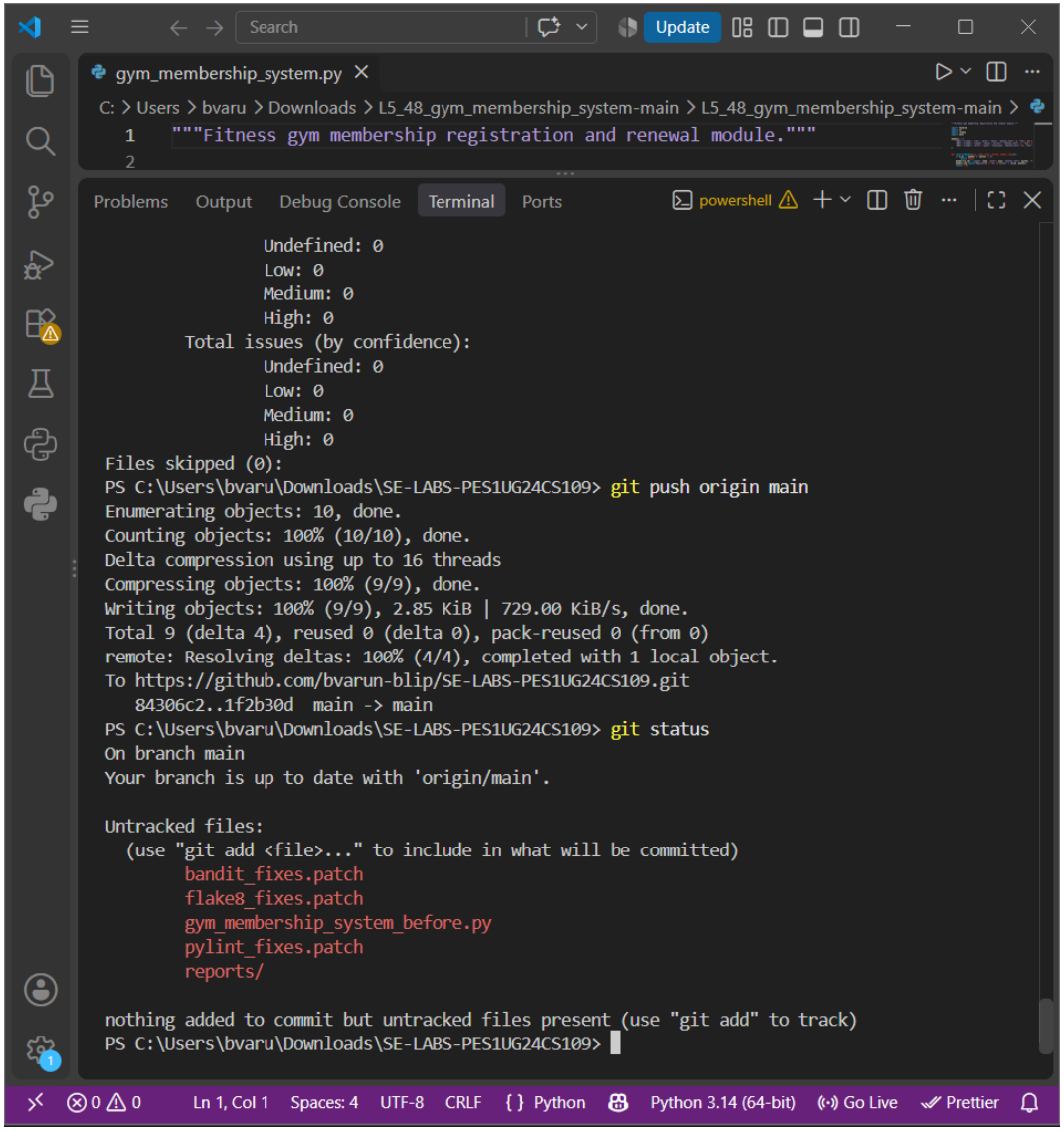
Git evidence - three separate commits

The terminal shows the three separate commits and their short hashes.



Git evidence - push to GitHub

The terminal shows the push to origin/main and confirms the local branch is up to date with origin/main.



Appendix B1. Pylint - before

Full contents of the supplied report file. Text is decoded from the original report encoding for readability; the report findings are preserved.

```
************* Module gym_membership_system
gym_membership_system.py:82:0: C0304: Final newline missing (missing-final-newline)
gym_membership_system.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
gym_membership_system.py:15:0: C0103: Function name "registerMember" doesn't conform to snake_case naming style (invalid-name)
gym_membership_system.py:15:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
gym_membership_system.py:19:22: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
gym_membership_system.py:23:0: C0116: Missing function or method docstring (missing-function-docstring)
gym_membership_system.py:23:0: C0103: Function name "cancelMembership" doesn't conform to snake_case naming style (invalid-name)
gym_membership_system.py:26:4: W0702: No exception type(s) specified (bare-except)
gym_membership_system.py:30:0: C0116: Missing function or method docstring (missing-function-docstring)
gym_membership_system.py:30:0: C0103: Function name "checkMembershipStatus" doesn't conform to snake_case naming style (invalid-name)
gym_membership_system.py:32:7: C0121: Comparison 'members.get(m_id) == None' should be 'members.get(m_id) is None' (singleton-comparison)
gym_membership_system.py:34:4: R1703: The if statement can be replaced with 'return bool(test)' (simplifiable-if-statement)
gym_membership_system.py:34:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return)
gym_membership_system.py:31:4: W0612: Unused variable 'locker_deposit' (unused-variable)
gym_membership_system.py:40:0: C0116: Missing function or method docstring (missing-function-docstring)
gym_membership_system.py:40:0: C0103: Function name "calculateRenewalRate" doesn't conform to snake_case naming style (invalid-name)
gym_membership_system.py:42:17: W0123: Use of eval (eval-used)
gym_membership_system.py:41:4: W0612: Unused variable 'base_fee' (unused-variable)
gym_membership_system.py:46:0: C0116: Missing function or method docstring (missing-function-docstring)
gym_membership_system.py:50:0: C0116: Missing function or method docstring (missing-function-docstring)
gym_membership_system.py:54:0: C0116: Missing function or method docstring (missing-function-docstring)
gym_membership_system.py:55:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
gym_membership_system.py:55:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
gym_membership_system.py:61:0: C0116: Missing function or method docstring (missing-function-docstring)
gym_membership_system.py:61:23: W0621: Redefining name 'members' from outer scope (line 8) (redefined-outer-name)
gym_membership_system.py:63:8: W0612: Unused variable 'm' (unused-variable)
gym_membership_system.py:69:0: C0116: Missing function or method docstring (missing-function-docstring)
gym_membership_system.py:6:0: W0611: Unused import math (unused-import)

-----------------------------------
Your code has been rated at 4.81/10
```

Appendix B2. Bandit - before

Full contents of the supplied report file. Text is decoded from the original report encoding for readability; the report findings are preserved.

```
py : [main]     INFO    profile include tests: None
At line:1 char:1
+ py -m bandit -r gym_membership_system.py > reports\bandit_before.txt  ...
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : NotSpecified: ([main] INFO    profile include tests: None:String)
    [], RemoteException
    + FullyQualifiedErrorId : NativeCommandError

[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.14.0
Run started:2026-10-30 11:13:52.959279+00:00

Test results:
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
   Location: .\gym_membership_system.py:26:4
25              del members[m_id]
26          except:
27              pass
28

--------------------------------------------------
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: .\gym_membership_system.py:42:17
41          base_fee = members[m_id]["fee"]
42          final_rate = eval(discount_expr)
43          return final_rate

--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\gym_membership_system.py:47:11
46      def generate_member_hash(m_id):
47          return hashlib.md5(m_id.encode()).hexdigest()
48

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\gym_membership_system.py:51:11
50      def generate_locker_pin():
51          return random.randint(1000, 9999)
52
```

```
--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\gym_membership_system.py:58:4
57          f.close()
58          os.system("echo Roster exported to: " + filename)
59

--------------------------------------------------
>> Issue: [B105:hardcoded_password_string] Possible hardcoded password: 'GYM_CLOUD_PORTAL_SECRET_2026'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html
   Location: .\gym_membership_system.py:70:21
69      def main():
70          gym_api_secret = "GYM_CLOUD_PORTAL_SECRET_2026"
71          registerMember("M04", "Diana", "Gold", 3)

--------------------------------------------------

Code scanned:
 Total lines of code: 60
 Total lines skipped (#nosec): 0
 Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
 Total issues (by severity):
  Undefined: 0
  Low: 3
  Medium: 1
  High: 2
 Total issues (by confidence):
  Undefined: 0
  Low: 0
  Medium: 1
  High: 5
Files skipped (0):
```

Appendix B3. Flake8 - before

Full contents of the supplied report file. Text is decoded from the original report encoding for readability; the report findings are preserved.

```
gym_membership_system.py:6:1: F401 'math' imported but unused
gym_membership_system.py:10:80: E501 line too long (80 > 79 characters)
gym_membership_system.py:11:80: E501 line too long (83 > 79 characters)
gym_membership_system.py:18:80: E501 line too long (93 > 79 characters)
gym_membership_system.py:26:5: E722 do not use bare 'except'
gym_membership_system.py:31:5: F841 local variable 'locker_deposit' is assigned to but never used
gym_membership_system.py:32:26: E711 comparison to None should be 'if cond is None:'
gym_membership_system.py:41:5: F841 local variable 'base_fee' is assigned to but never used
gym_membership_system.py:82:7: W292 no newline at end of file
```

Appendix B4. Pylint - after

Full contents of the supplied report file. Text is decoded from the original report encoding for readability; the report findings are preserved.

```
--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 4.81/10, +5.19)
```

Appendix B5. Bandit - after

Full contents of the supplied report file. Text is decoded from the original report encoding for readability; the report findings are preserved.

```
py : [main]     INFO    profile include tests: None
At line:1 char:1
+ py -m bandit -r gym_membership_system.py > reports\bandit_after.txt 2 ...
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : NotSpecified: ([main] INFO    profile include tests: None:String)
    [], RemoteException
    + FullyQualifiedErrorId : NativeCommandError

[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.14.0
Run started:2026-10-30 11:52:37.093760+00:00

Test results:
 No issues identified.

Code scanned:
 Total lines of code: 76
 Total lines skipped (#nosec): 0
 Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
 Total issues (by severity):
  Undefined: 0
  Low: 0
  Medium: 0
  High: 0
 Total issues (by confidence):
  Undefined: 0
  Low: 0
  Medium: 0
  High: 0
Files skipped (0):
```

Appendix B6. Flake8 - after

The report file is empty (0 bytes). Flake8 emitted no output after the fixes, which indicates no remaining Flake8 violations.